

Lab: SonarQube-Based Static Application Security Testing (SAST) of DVWA

Objective: The objective of this document is to configure SonarQube and scan the source code of a vulnerable web application (DVWA) to perform a detailed security analysis. By the end of this exercise, we will be able to identify critical issues such as code injection and insecure permissions, understand their security impact, and gain hands-on experience in analyzing and interpreting scan results to improve code security.

Tools required: Windows Server 2022, SonarQube

Prerequisites: Basics of Web Applications

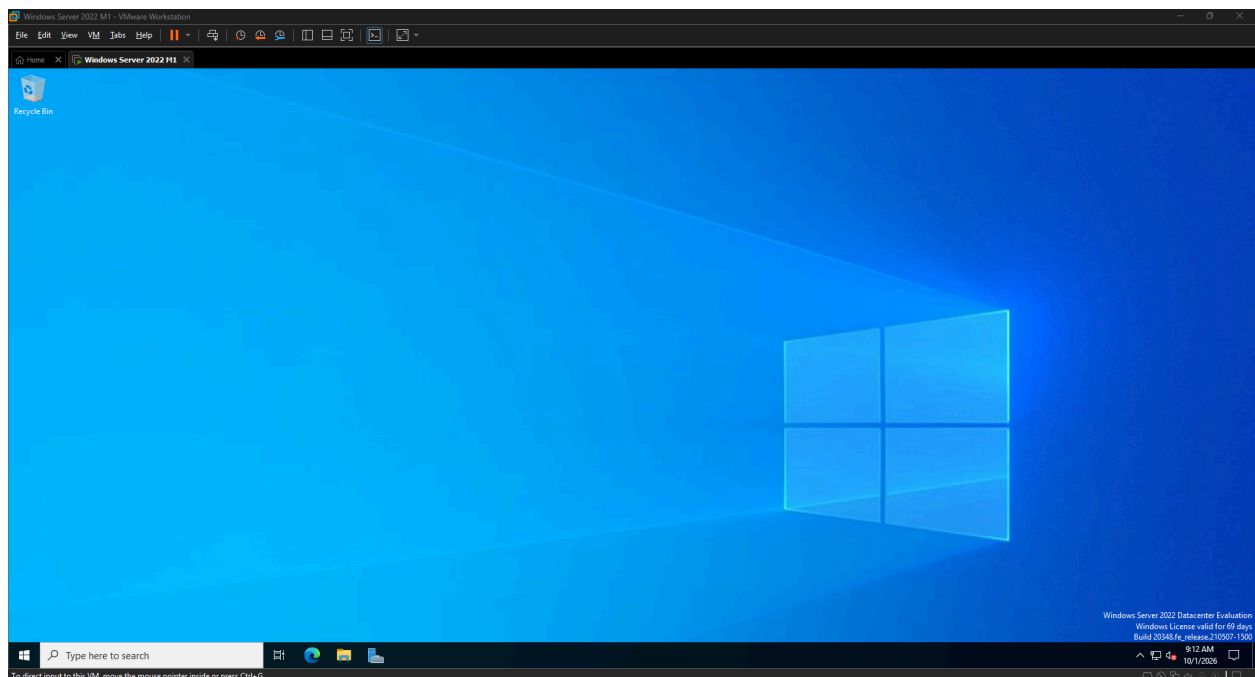
Steps to be followed:

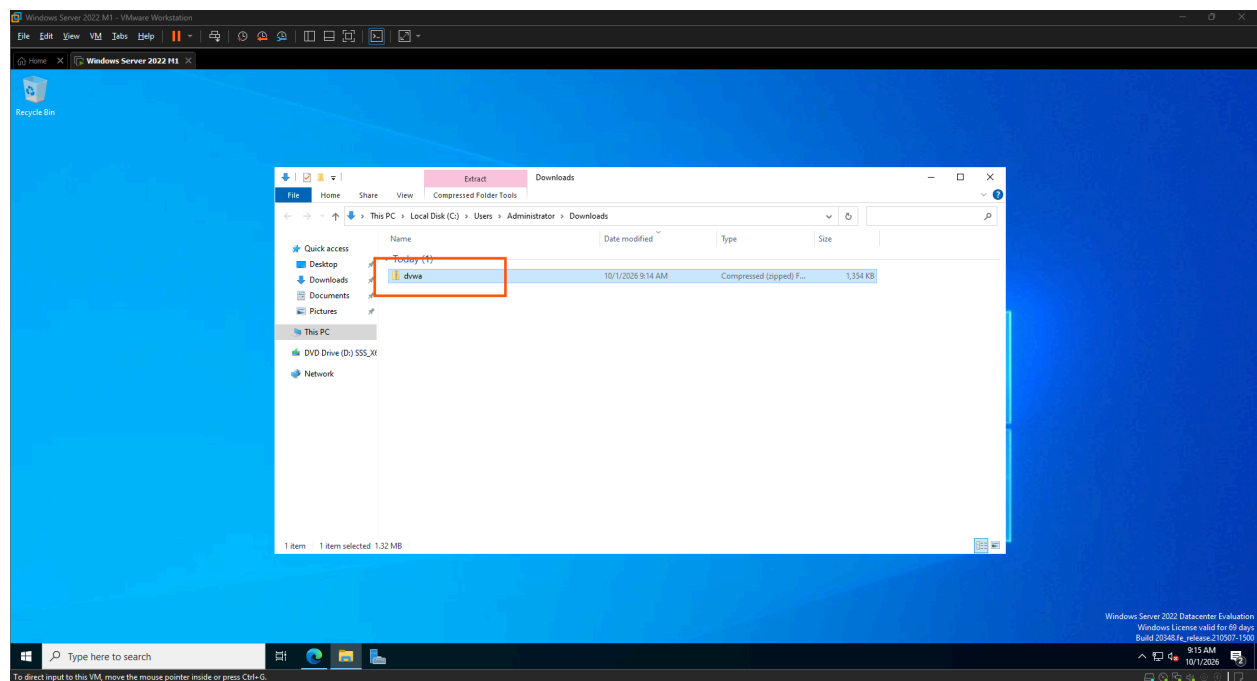
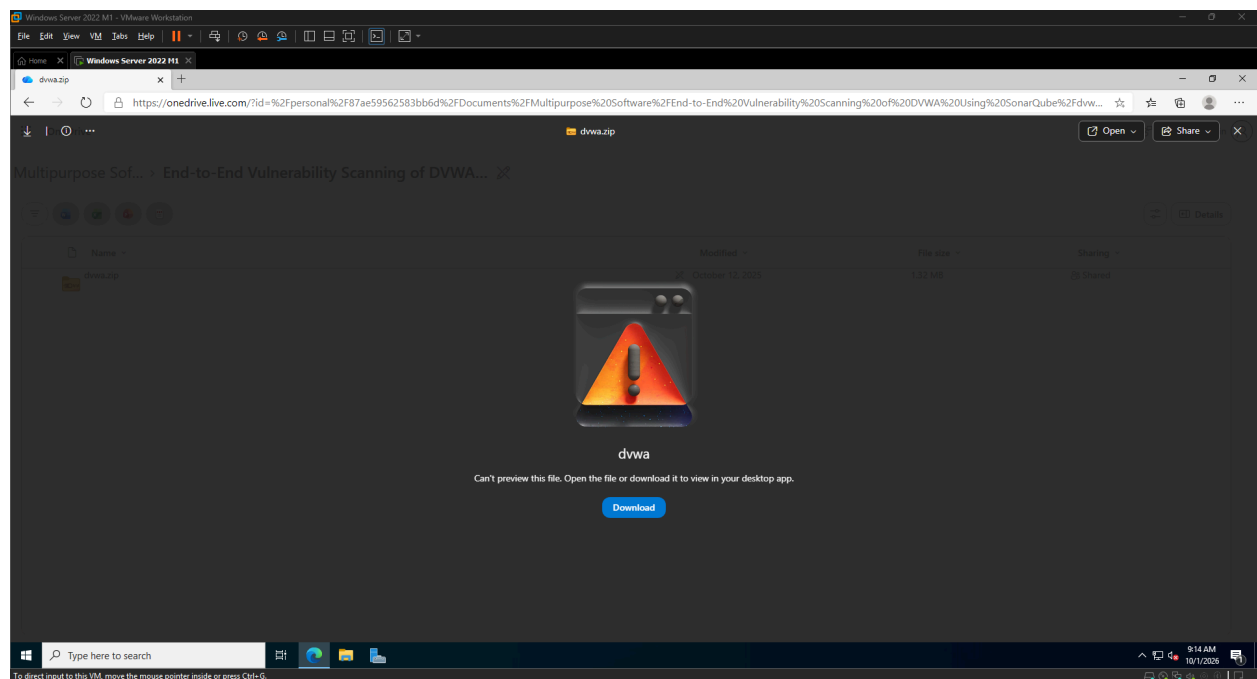
1. Download the source code.
2. Download and install the dependencies.
3. Setup the SonarQube.
4. Scan the source code

Step 1: Download the source code.

1.1 download the DVWA source code using the link provided below.

<https://1drv.ms/u/c/87ae59562583bb6d/Eby990oYpJJPgXSReY0wUDsB2HPH6X9Mb76piVaDviNfQg?e=hImpTd>

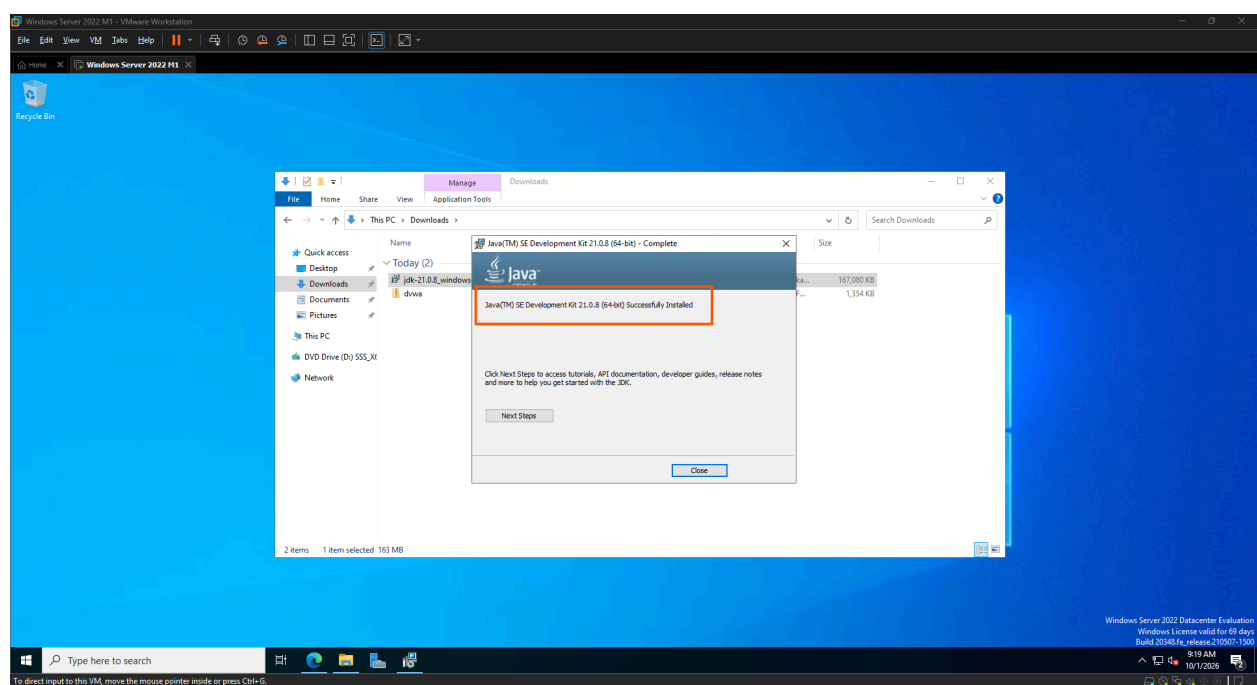
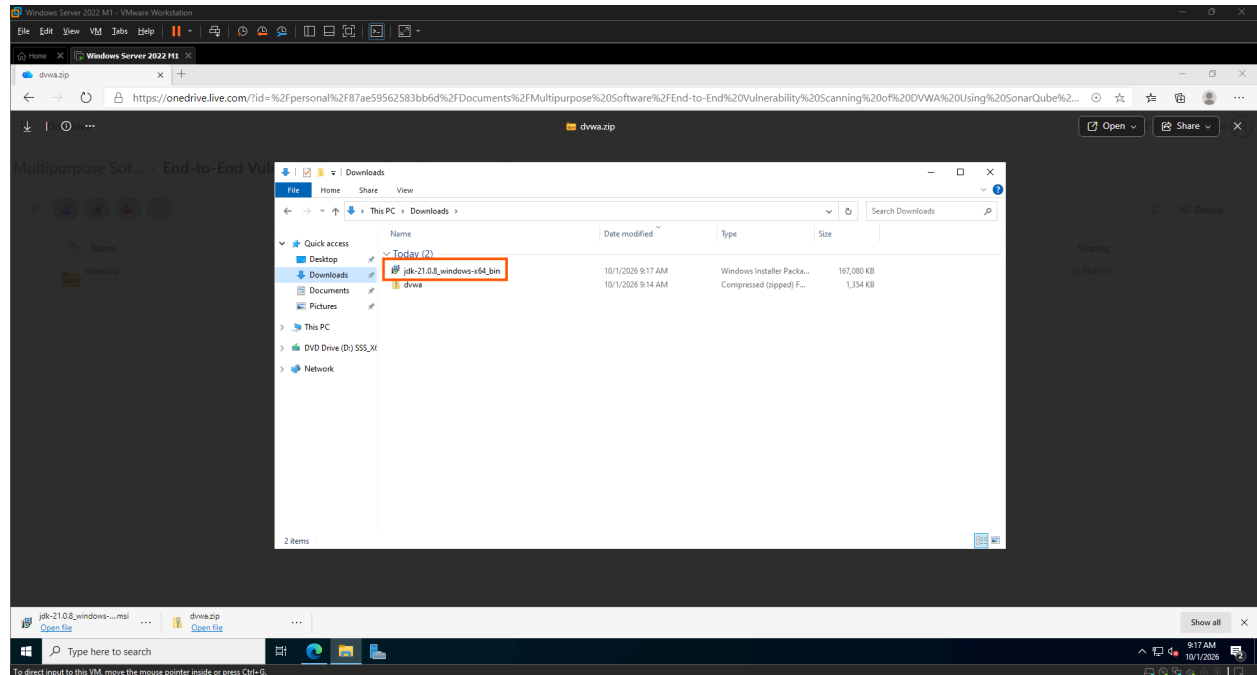




Task 2: Download and install the dependencies.

2.1 Download the java 21 using the link below and install it:

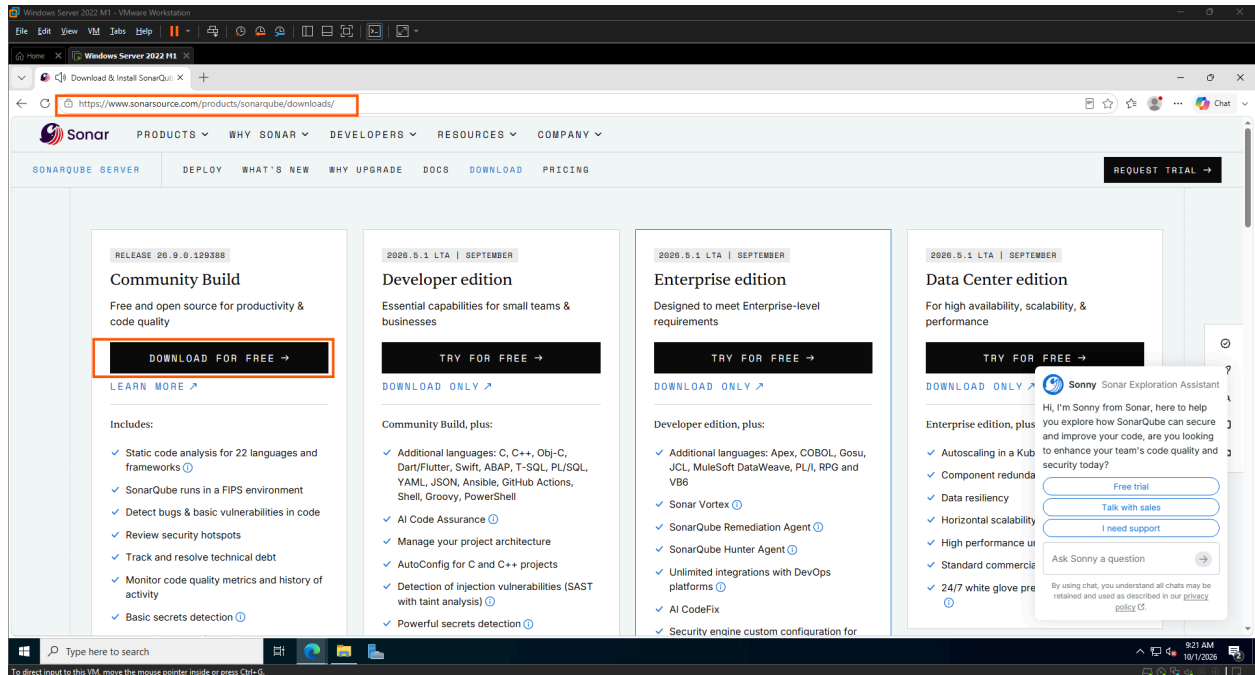
https://download.oracle.com/java/21/archive/jdk-21.0.8_windows-x64_bin.msi



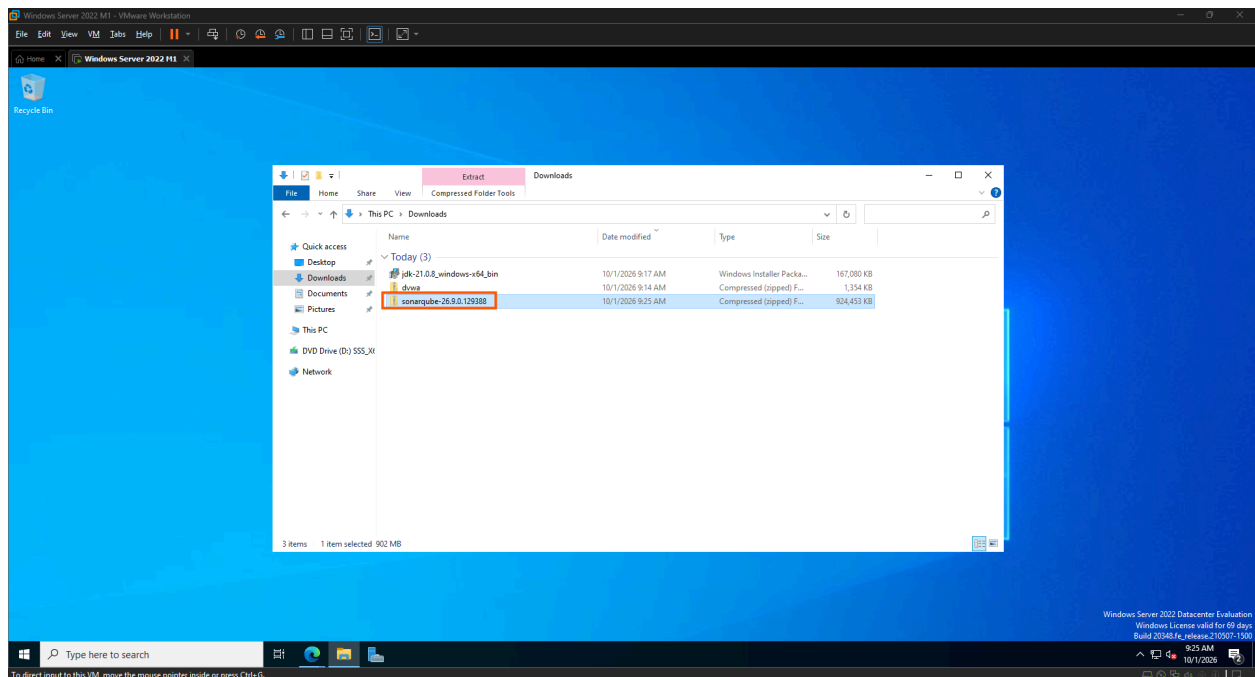
Task 3: Setup SonarQube.

3.1 Use the link below to download SonarQube.

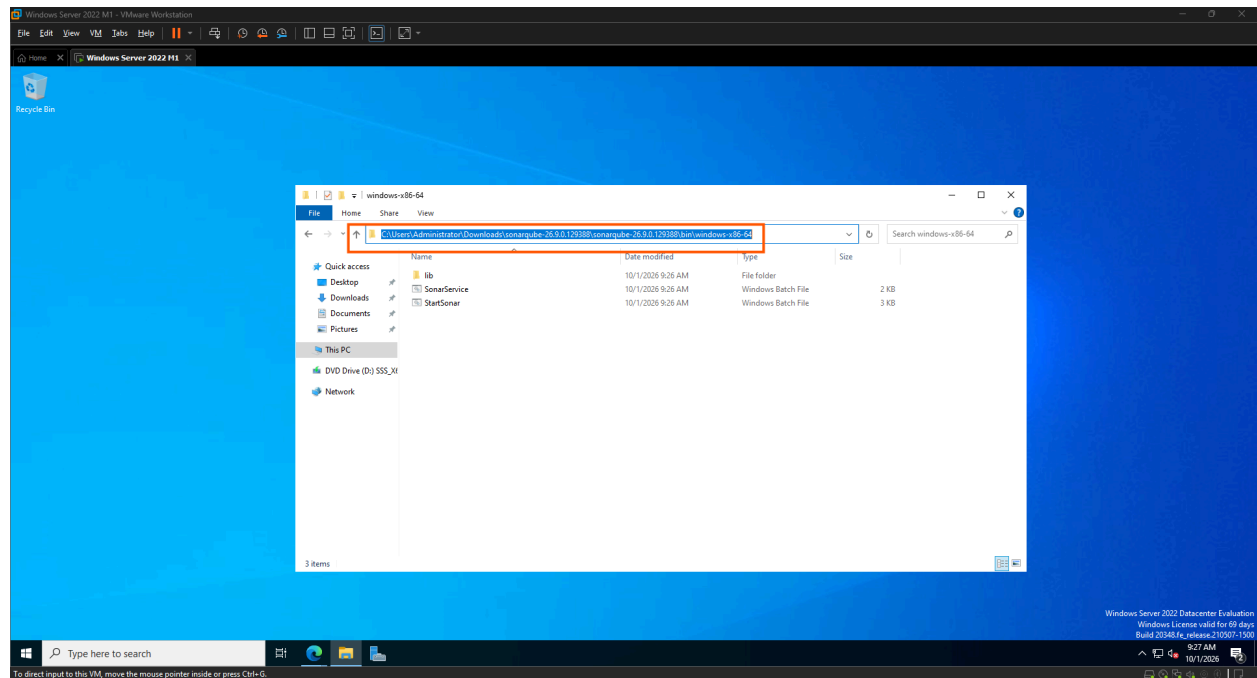
Link: <https://www.sonarqube.org/downloads/>



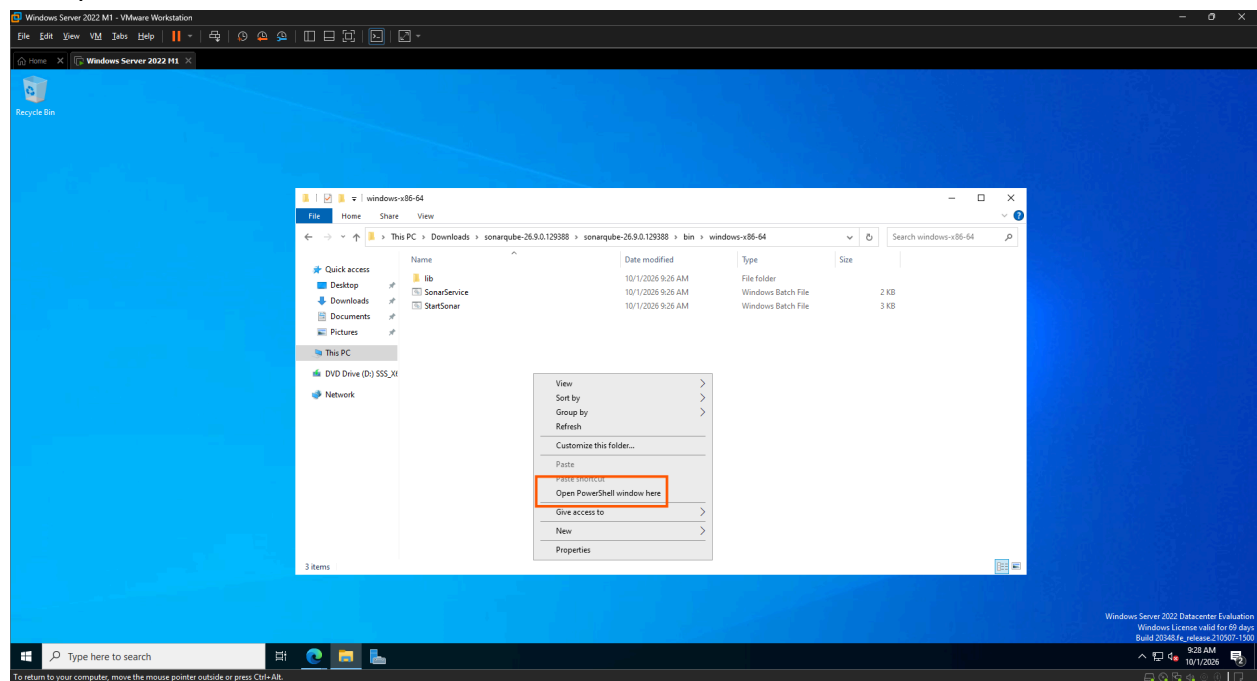
3.2 Open the file manager and extract SonarQube zip file



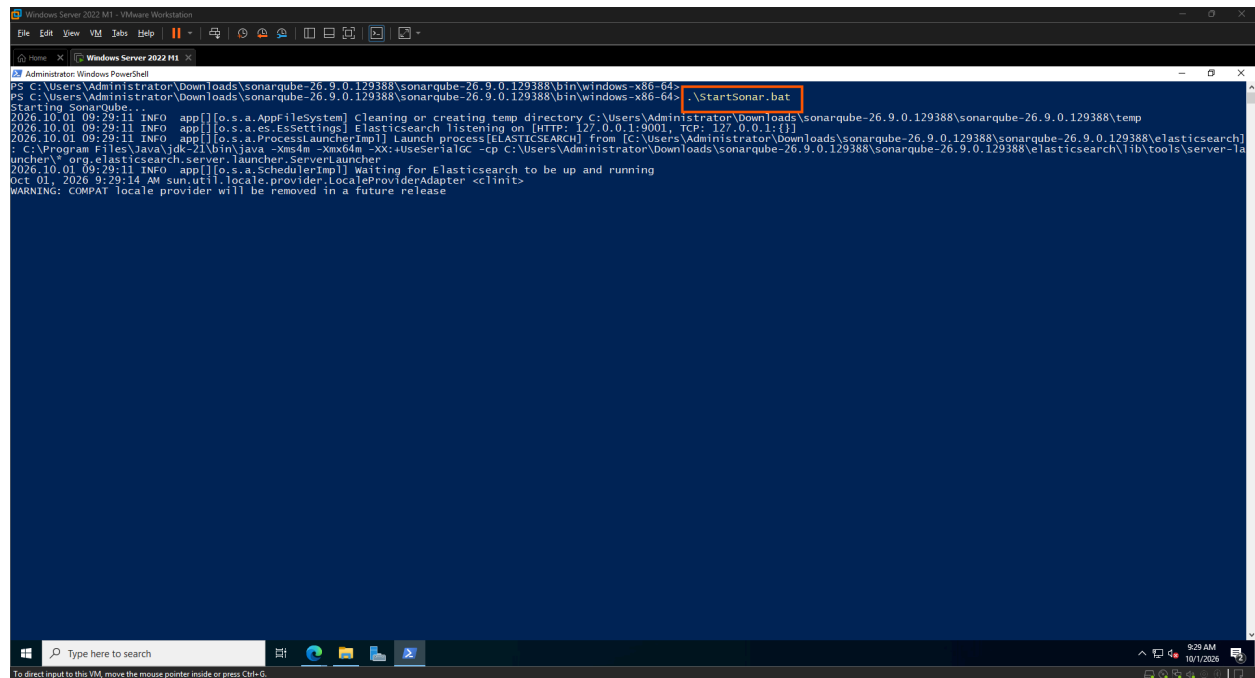
3.3 Now navigate to Downloads\sonarqube-*.*.sonarqube-*.*.bin\windows-x86-64



3.4 Open PowerShell windows here

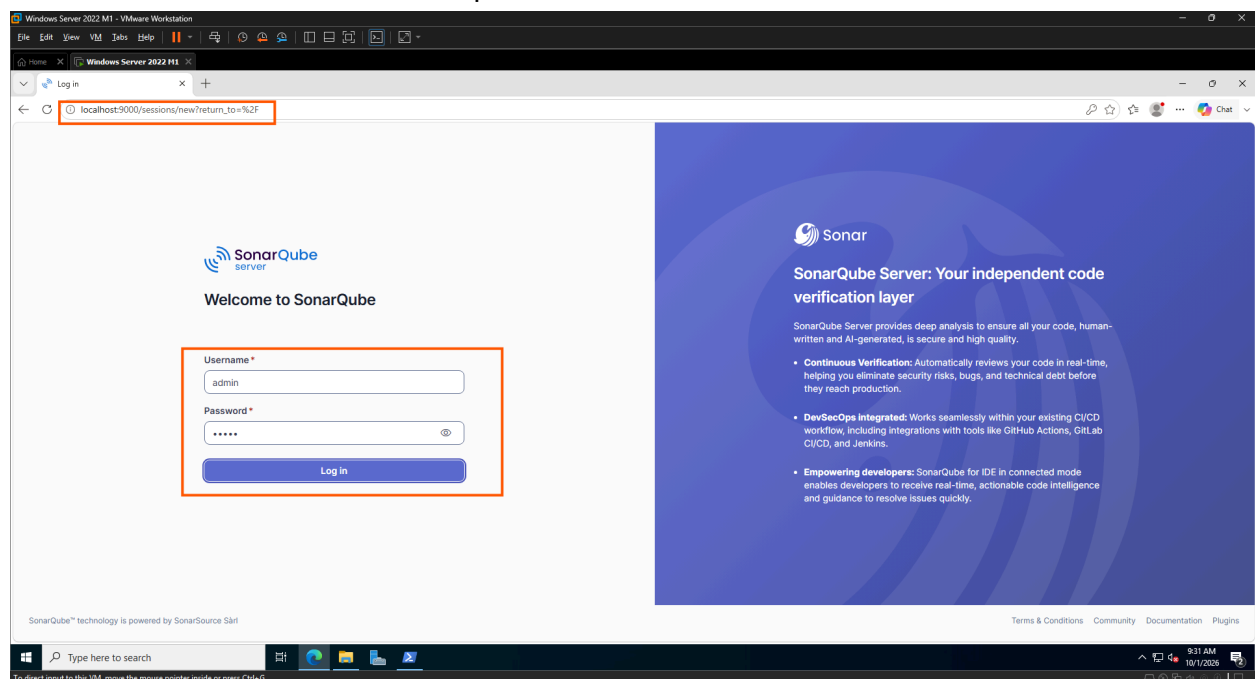


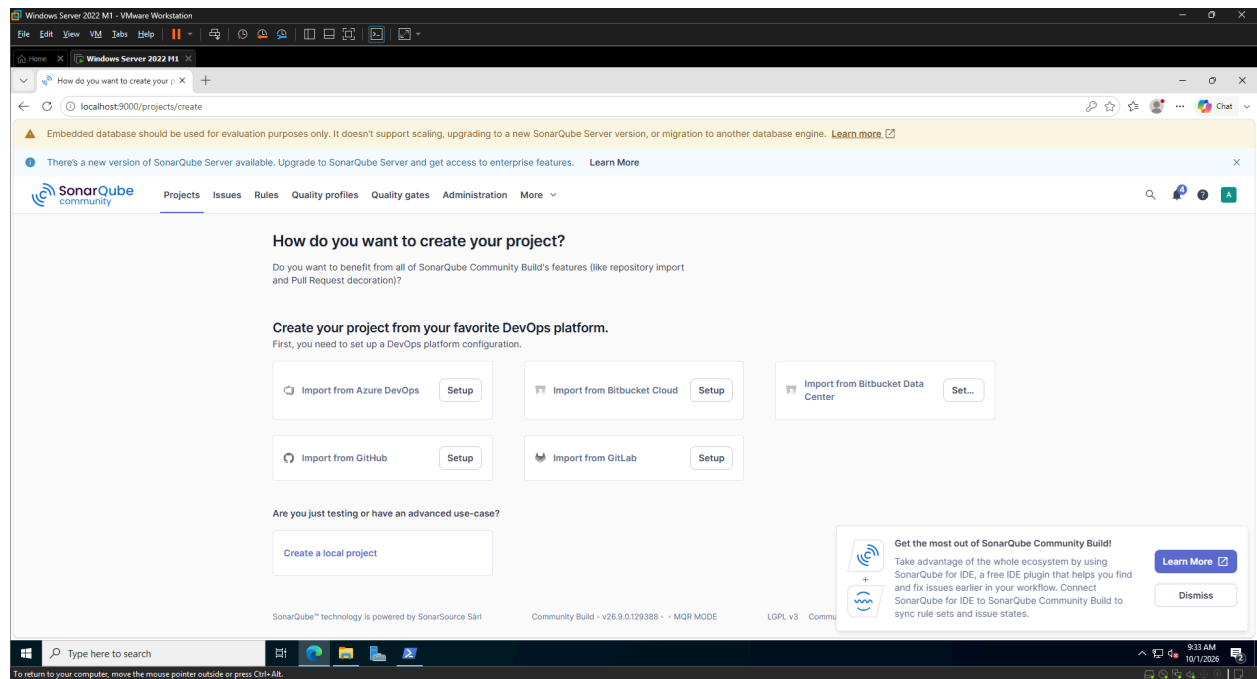
3.5 Now run the SonarQube using the command: `.\startsonar.bat`



3.6 Open the browser and search: <http://localhost:9000>

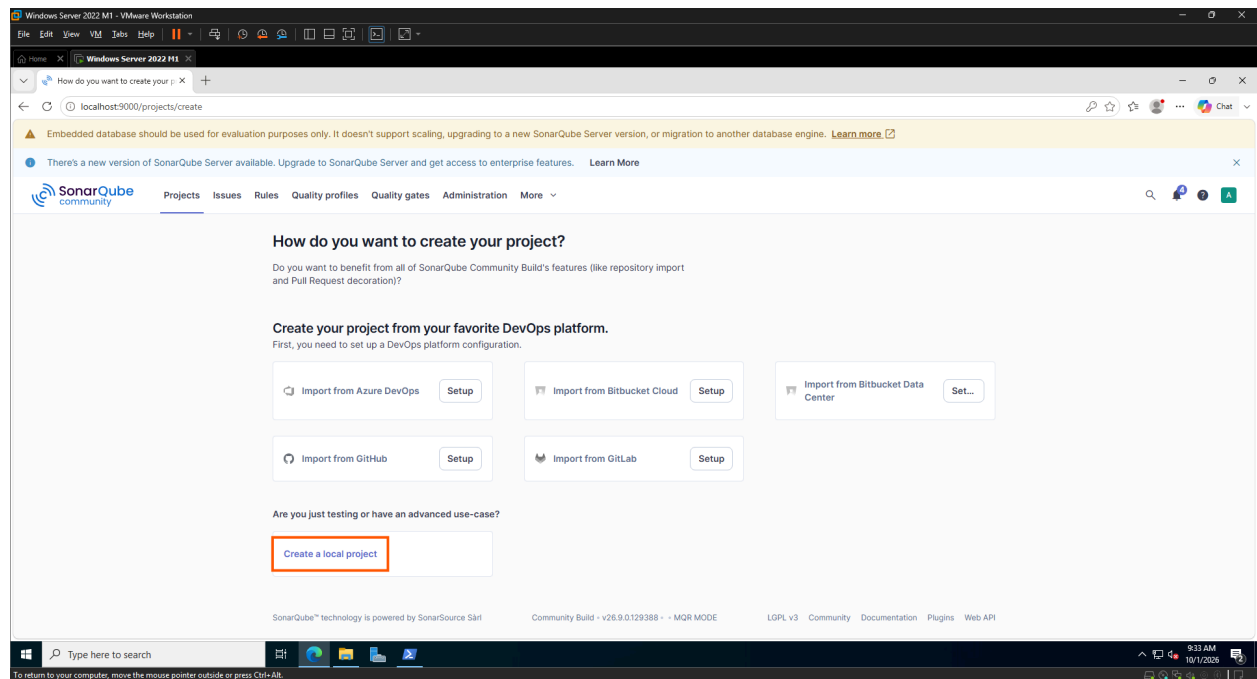
3.7 Enter the default username and password as admin/admin

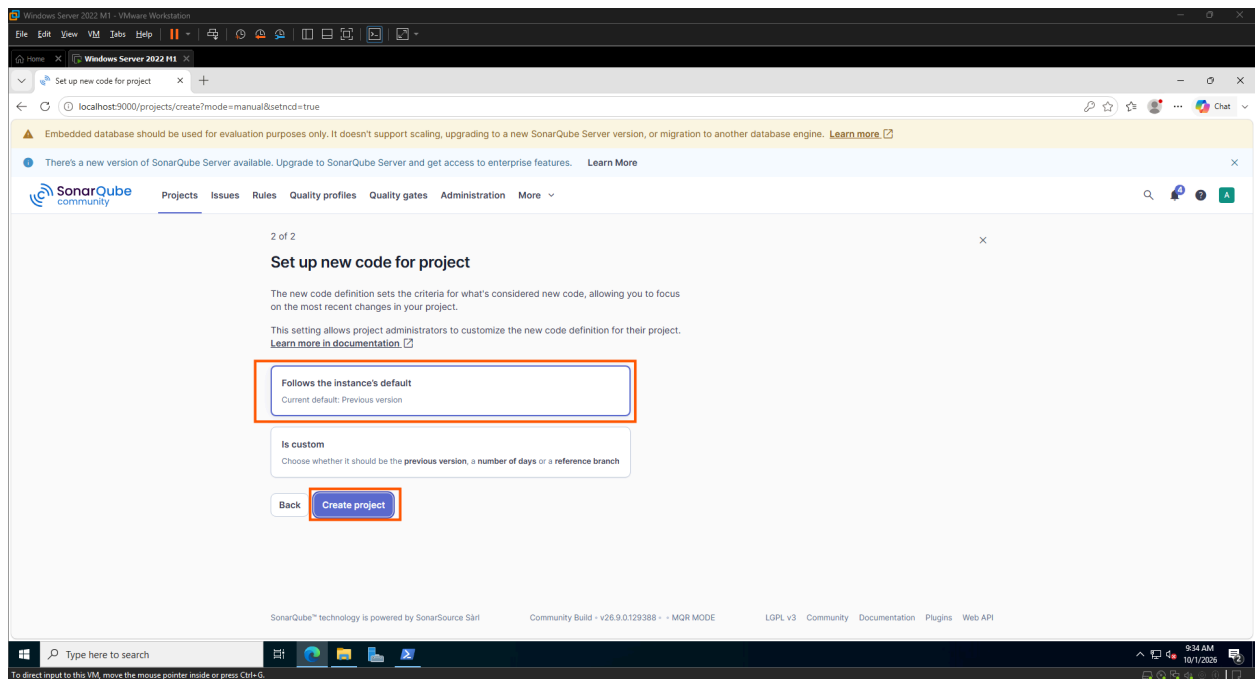
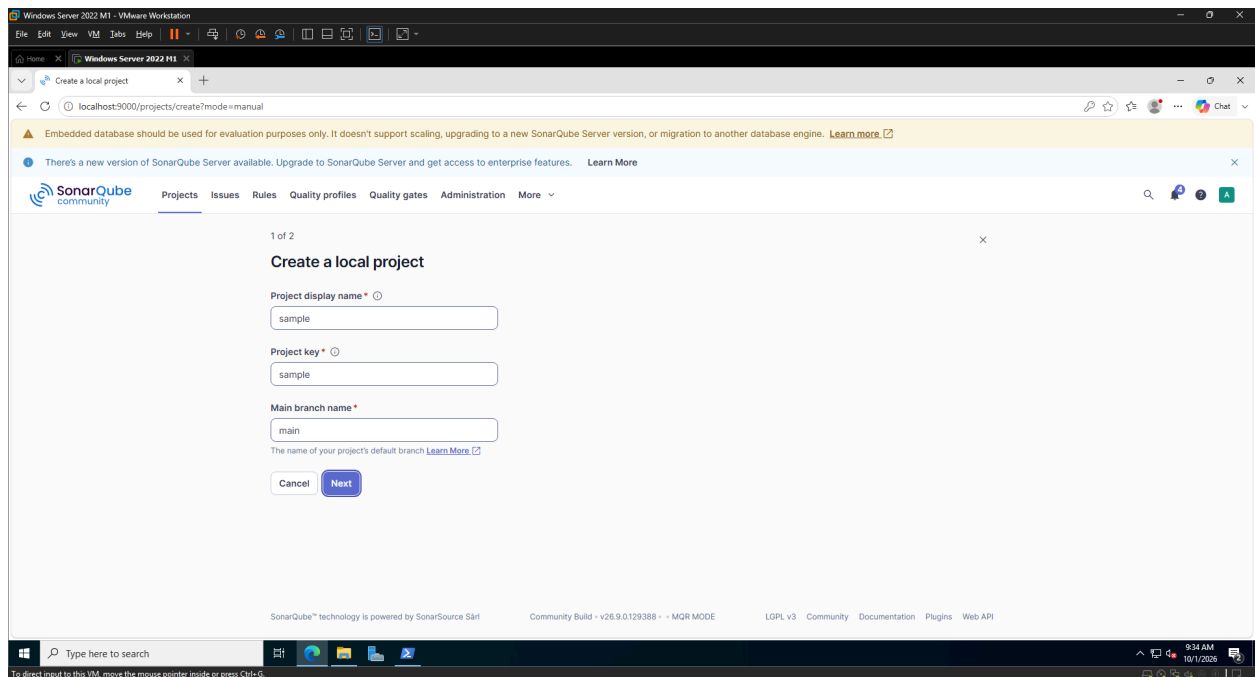


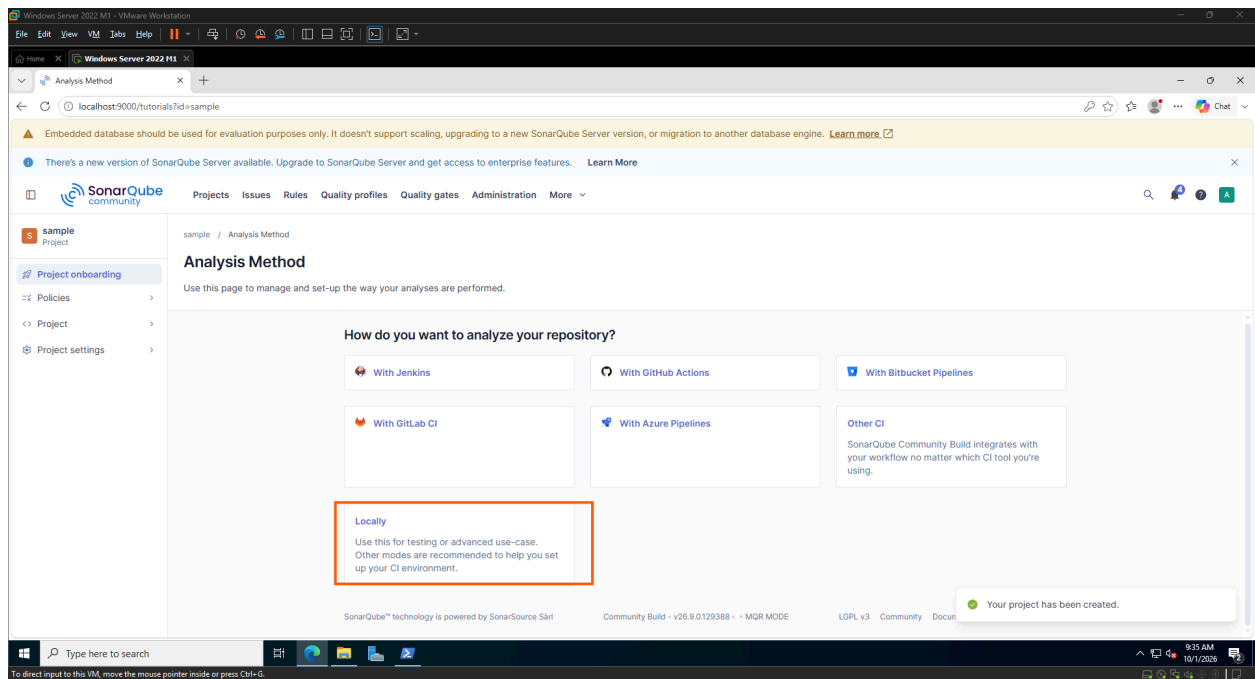


Task 4: Scan the source code

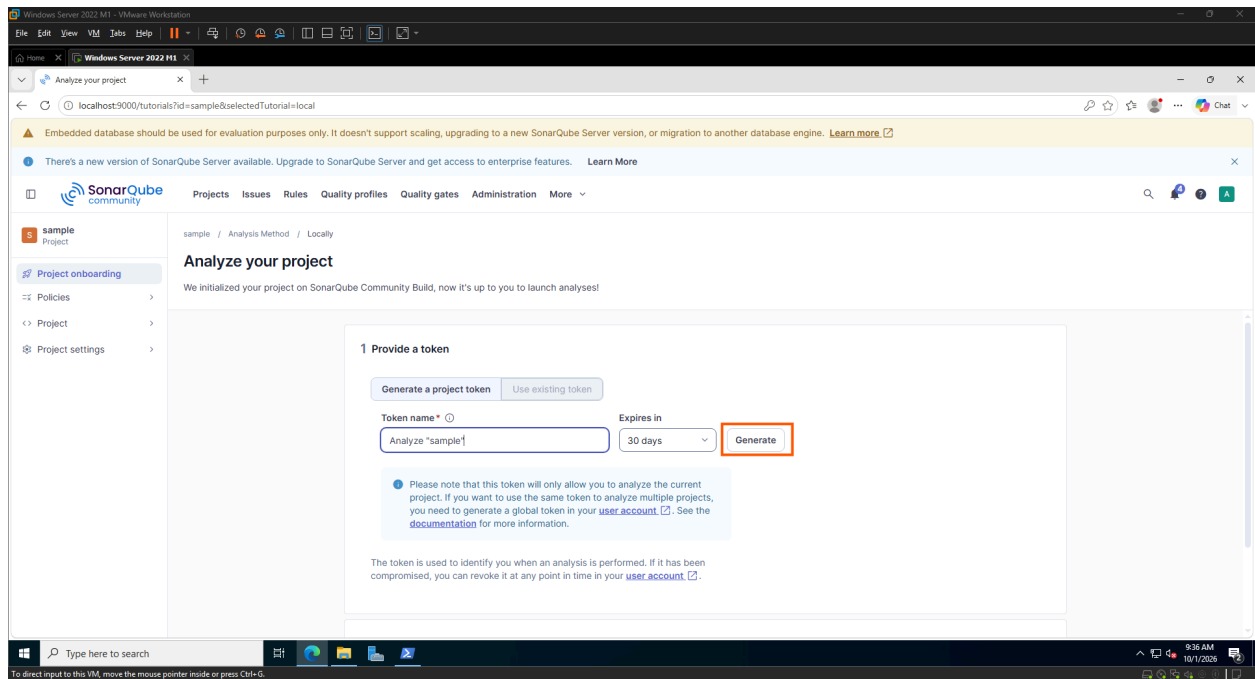
4.1 Create a local project

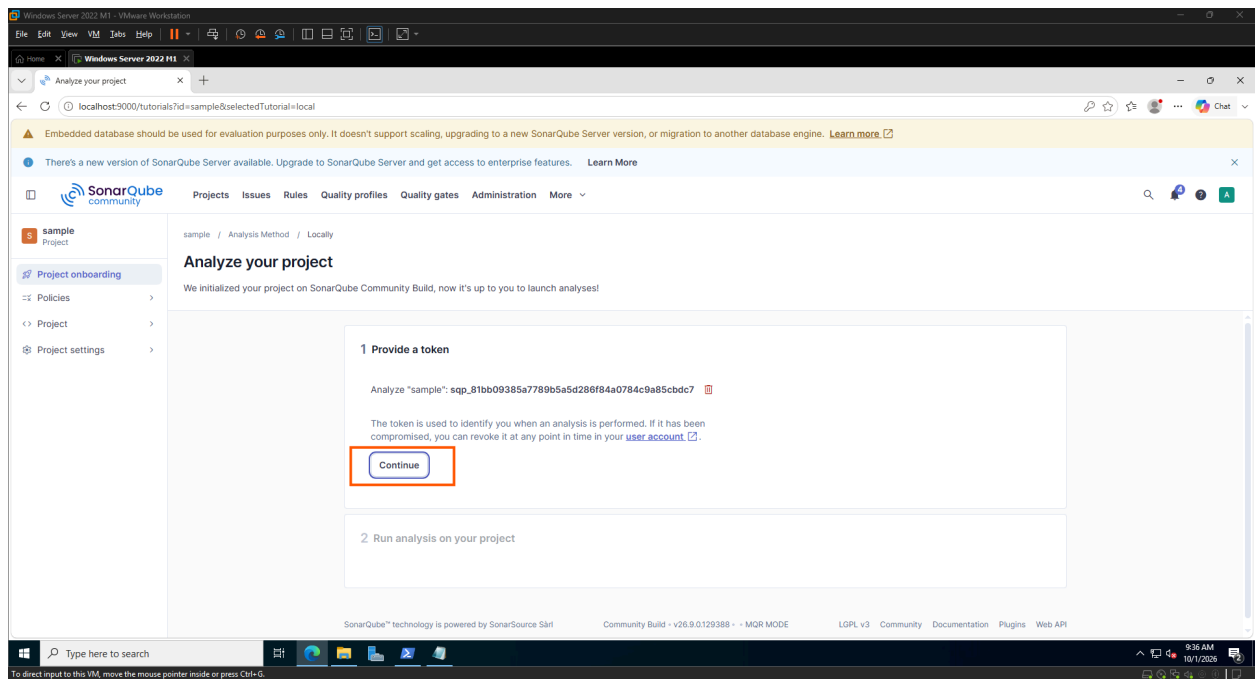




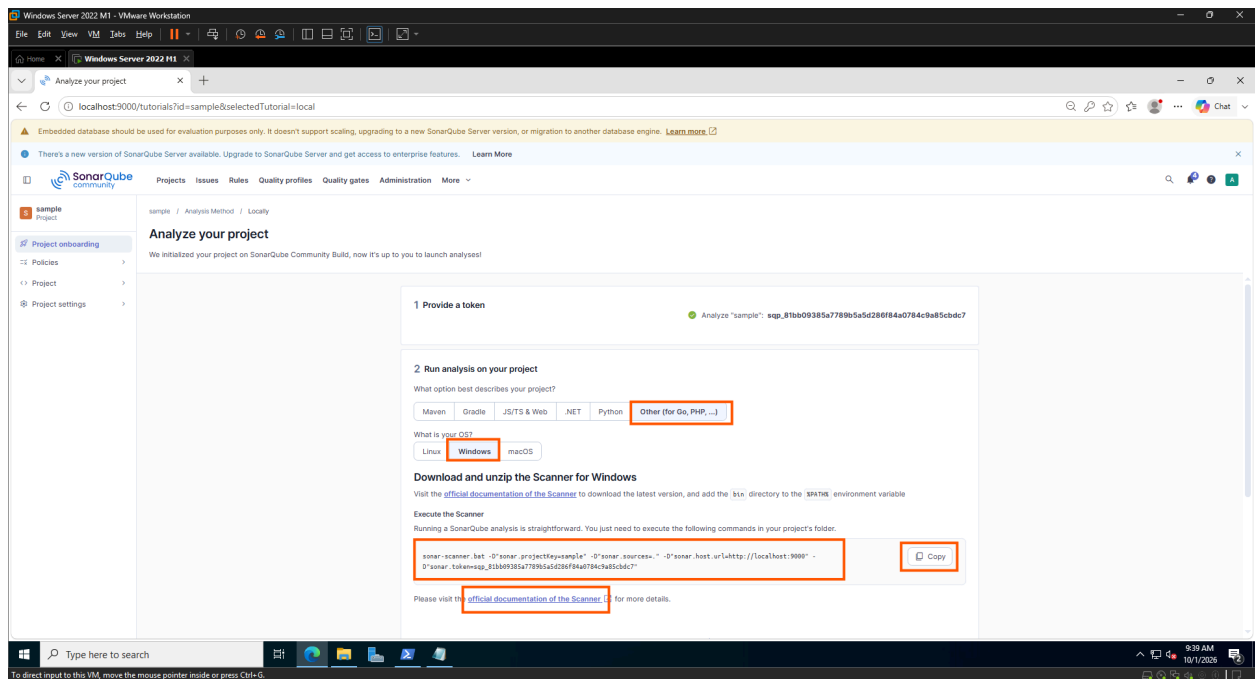


4.2 Generate Project Token

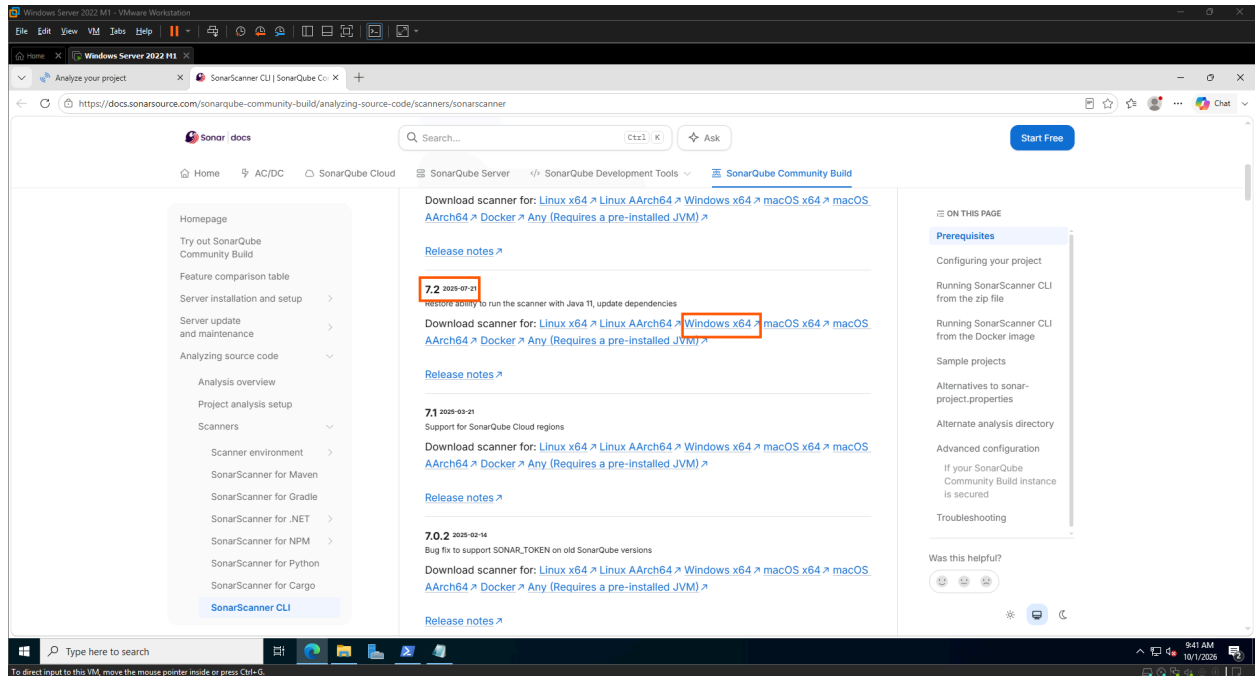




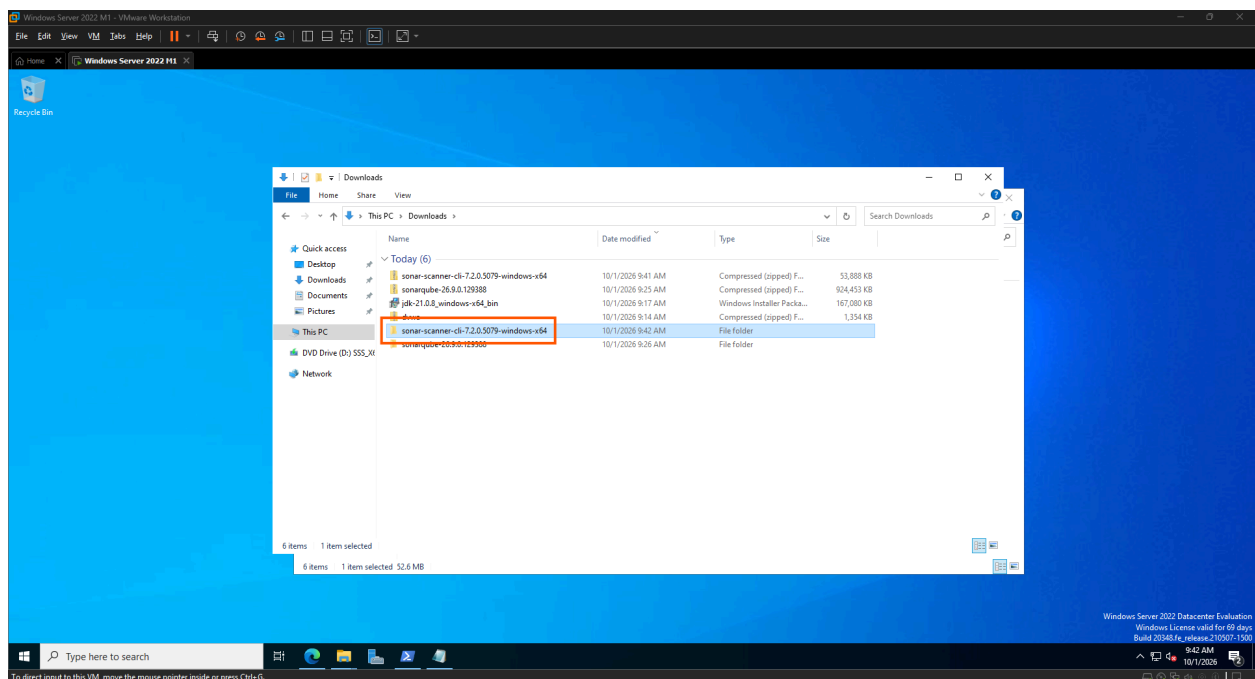
4.3 Choose Project Option, OS, copy the command given for running sonarqube analysis & then navigate to previous page and click on “official document of the Scanner”



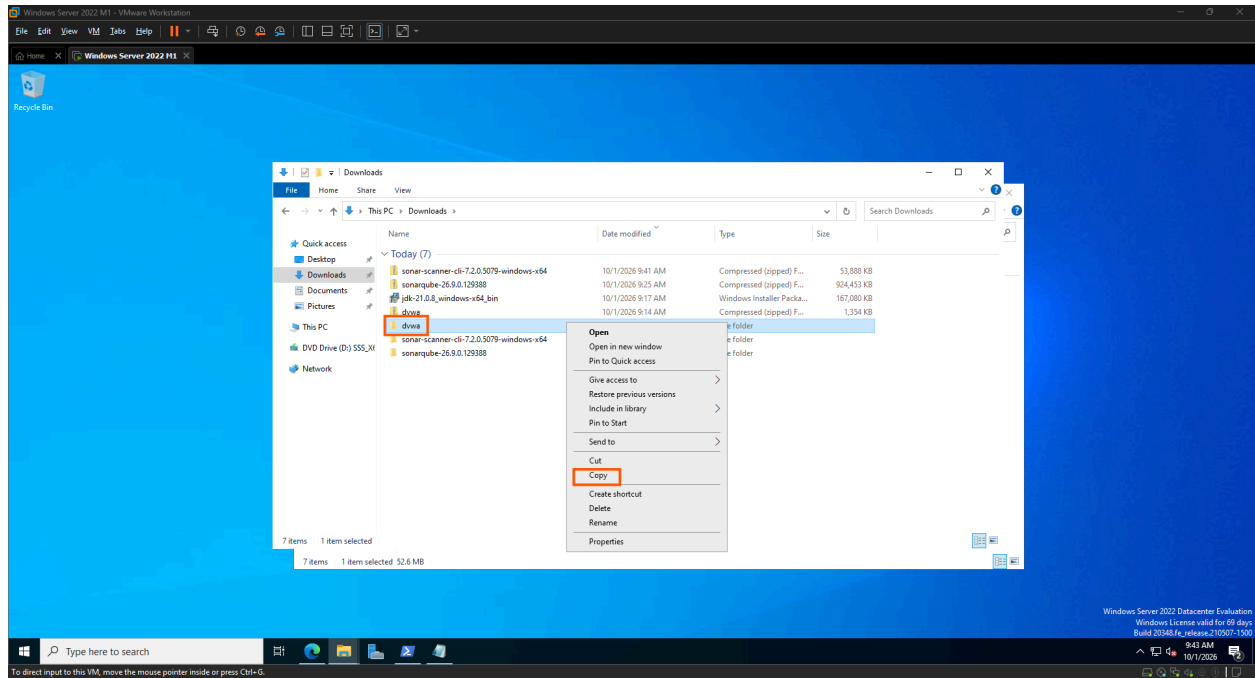
4.4 Select Windows x64 listed under the 7.2 version to begin the download.



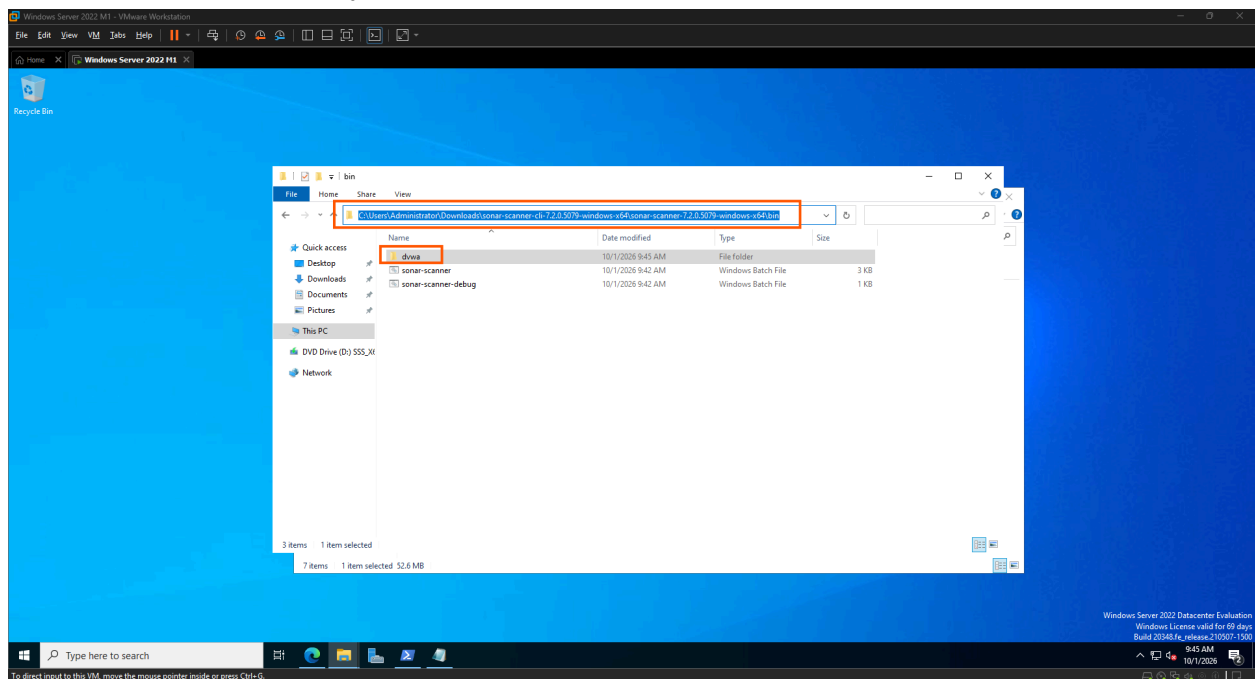
4.5 Extract the downloaded SonarQube CLI



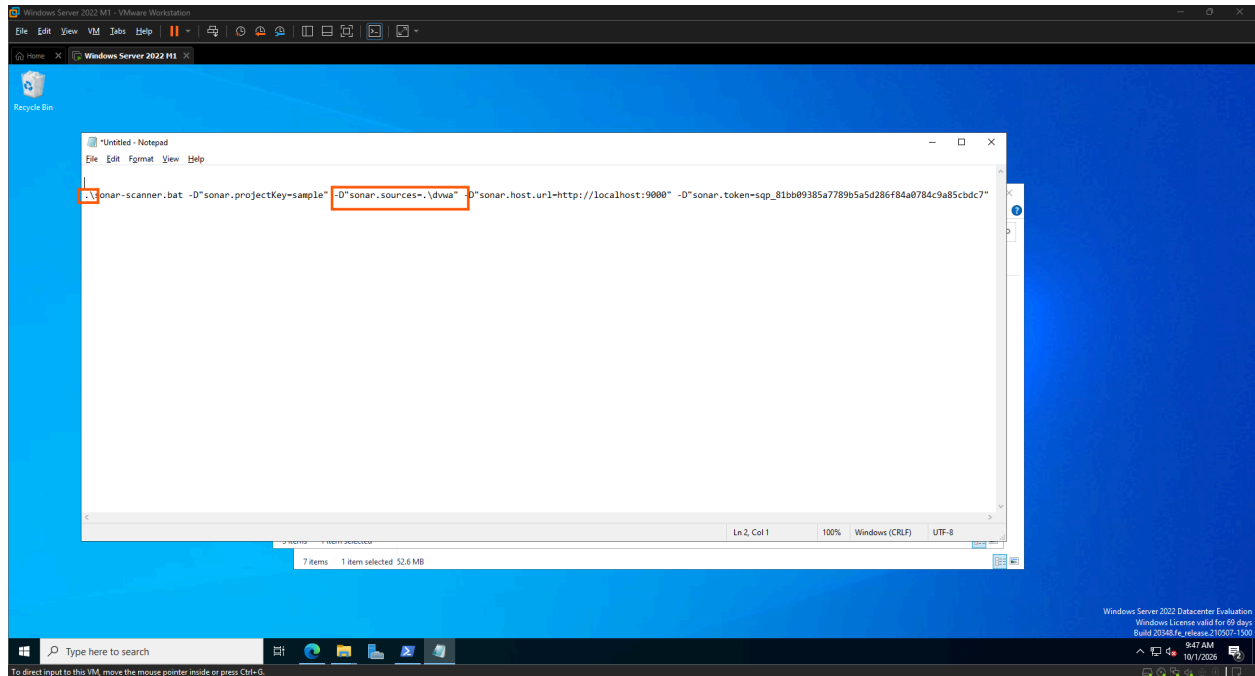
4.6 Copy the dvwa source code



4.7 Navigate to **Download > sonar-scanner-cli-* > sonar-scanner-* > bin** and Inside the bin directory paste the dvwa source code folder.

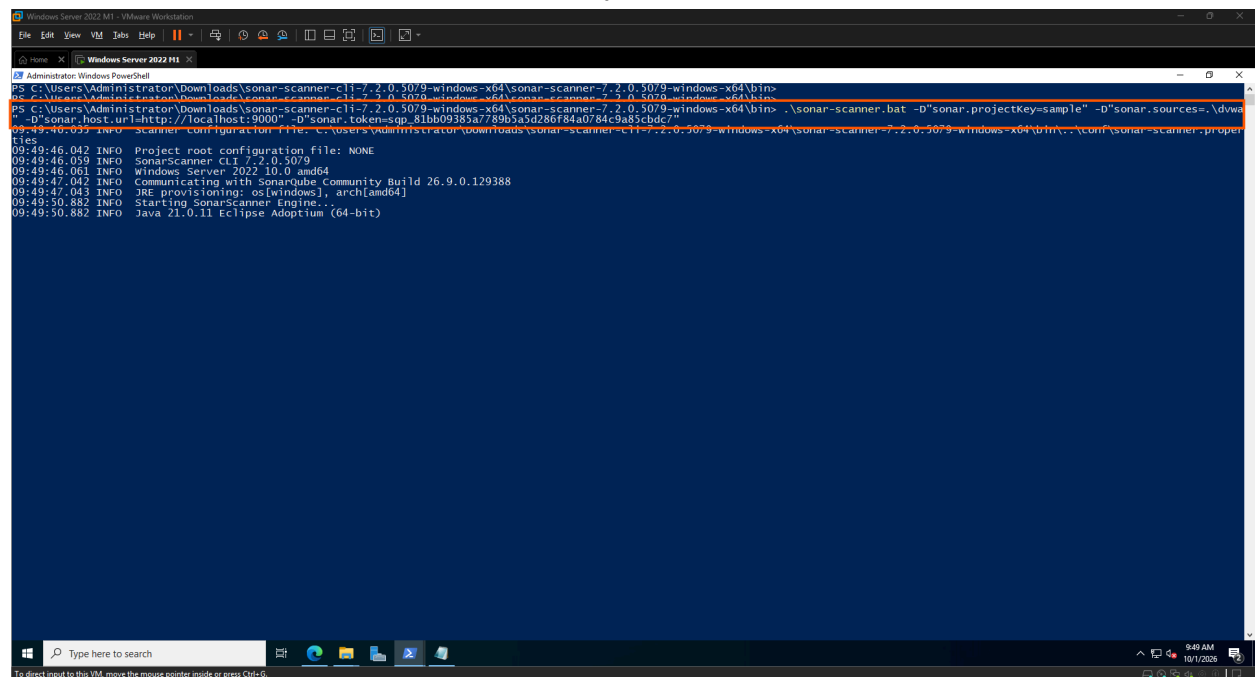


4.8 Open the notepad and modify the command to add code source path to analyze

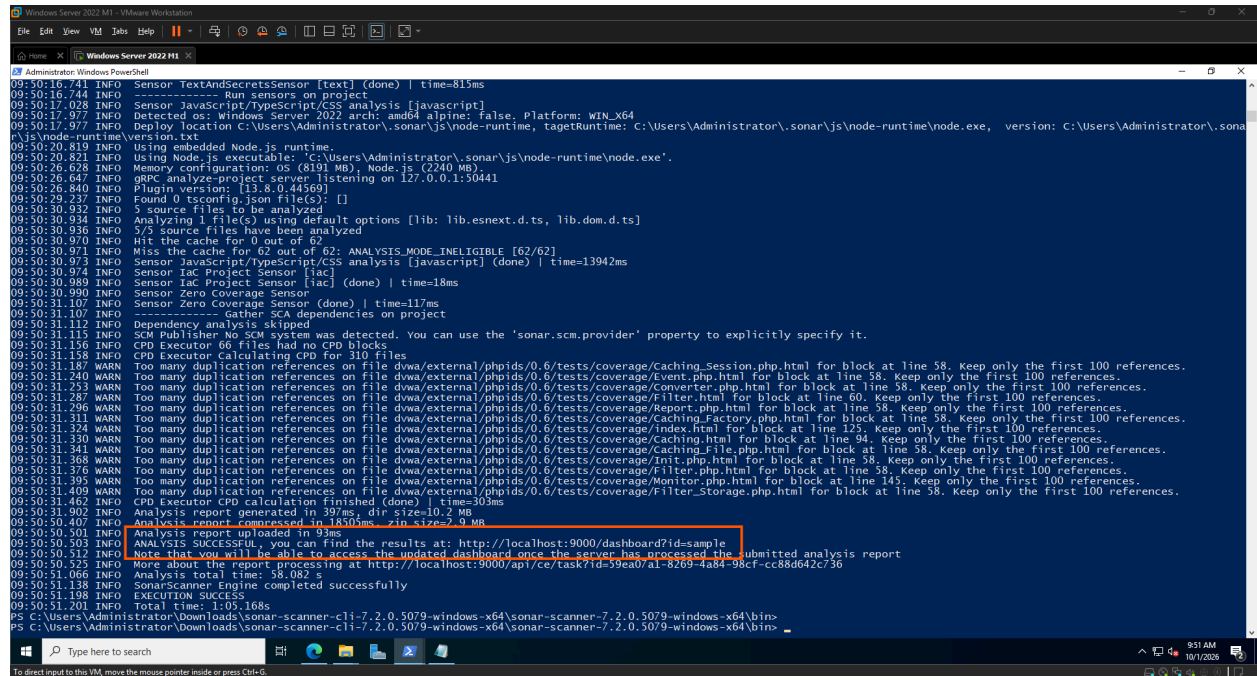


4.9 Copy the command & Navigate to bin directory where we added source code folder

4.10 Open PowerShell here & Paste the modify command

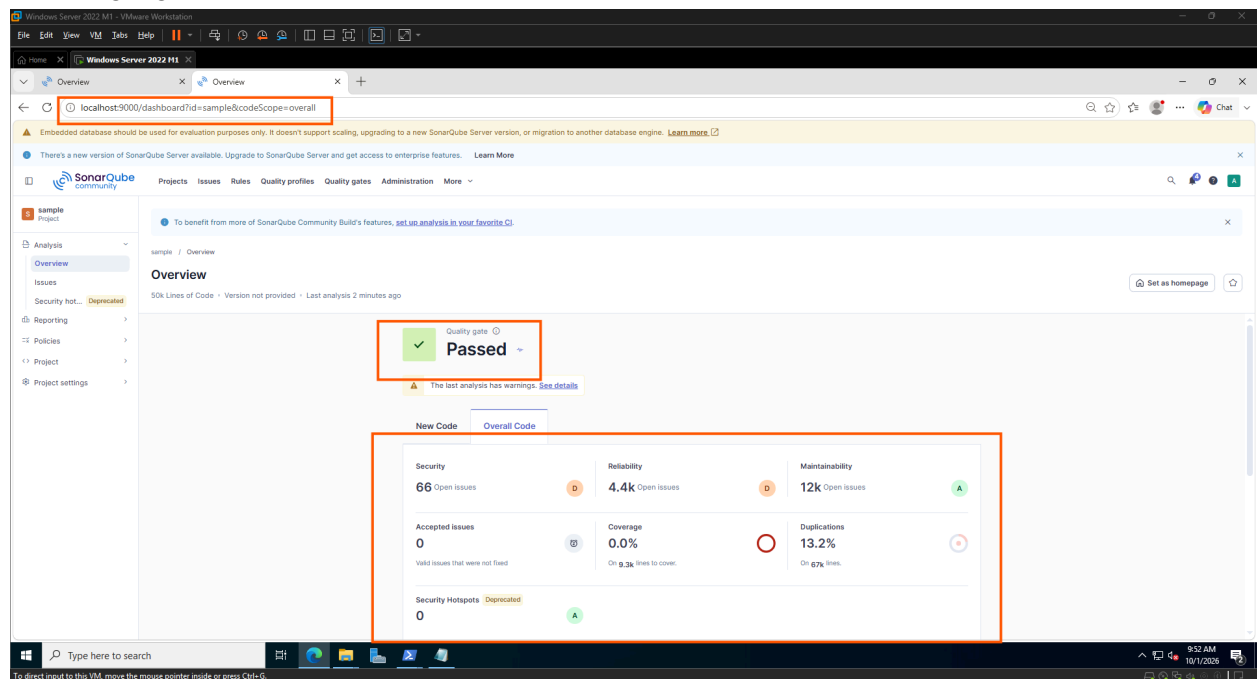


4.11 Once Analysis is complete, copy the highlighted url

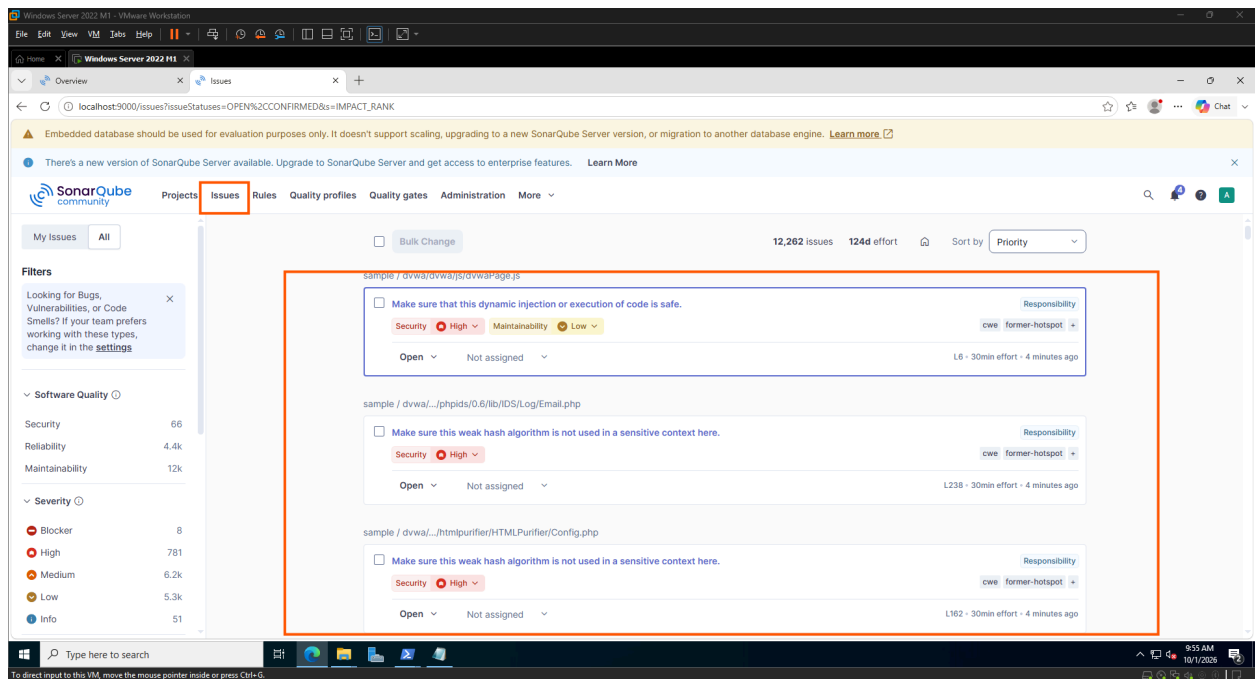


```
09:50:16.741 INFO Sensor TextAndSecretsSensor [text] (done) | time=813ms
09:50:16.744 INFO ----- Run sensors on project
09:50:17.026 INFO Sensor JavaScript/TypeScript/CSS analysis [javascript]
09:50:17.977 INFO Detected os: Windows Server 2022 arch: amd64 alpine: false, Platform: WIN_X64
09:50:17.977 INFO Deploy location C:\Users\Administrator\sonar\js\node-runtime, targetRuntime: C:\Users\Administrator\sonar\js\node-runtime\node.exe, version: C:\Users\Administrator\sonar\js\node-runtime\version.txt
09:50:20.819 INFO Using embedded Node.js runtime.
09:50:20.821 INFO Using Node.js executable: 'C:\Users\Administrator\sonar\js\node-runtime\node.exe'.
09:50:26.628 INFO Memory configuration: OS (8191 MB), Node.js (2240 MB)
09:50:26.647 INFO gRPC analyze-project server listening on 127.0.0.1:50441
09:50:26.840 INFO Plugin version: [13.8.0.44569]
09:50:29.527 INFO Found 0 tsconfig.json file(s): []
09:50:30.932 INFO 5 source files to be analyzed
09:50:30.934 INFO Analyzing 1 file(s) using default options [lib: lib.esnext.d.ts, lib.dom.d.ts]
09:50:30.936 INFO 5/5 source files have been analyzed
09:50:30.970 INFO Hit the cache for 0 out of 62
09:50:30.971 INFO Miss the cache for 62 out of 62: ANALYSIS_MODE_INELIGIBLE [62/62]
09:50:30.973 INFO Sensor JavaScript/TypeScript/CSS analysis [javascript] (done) | time=13942ms
09:50:30.974 INFO Sensor Iac Project Sensor [iac]
09:50:30.989 INFO Sensor Iac Project Sensor [iac] (done) | time=18ms
09:50:30.990 INFO Sensor Zero Coverage Sensor
09:50:31.107 INFO Sensor Zero Coverage Sensor (done) | time=117ms
09:50:31.107 INFO ----- Gather SCA dependencies on project
09:50:31.112 INFO Dependency analysis skipped
09:50:31.113 INFO SCM Publisher No SCM system was detected. You can use the 'sonar.scm.provider' property to explicitly specify it.
09:50:31.150 INFO CPD Executor 66 files had no CPD blocks
09:50:31.158 INFO CPD Executor Calculating CPD for 310 files
09:50:31.187 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/caching_session.php.html for block at line 58. Keep only the first 100 references.
09:50:31.240 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Event.php.html for block at line 58. Keep only the first 100 references.
09:50:31.253 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Converter.php.html for block at line 58. Keep only the first 100 references.
09:50:31.287 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Filter.html for block at line 60. Keep only the first 100 references.
09:50:31.290 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Report.php.html for block at line 58. Keep only the first 100 references.
09:50:31.311 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Caching_Factory.php.html for block at line 58. Keep only the first 100 references.
09:50:31.324 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Cache.php.html for block at line 58. Keep only the first 100 references.
09:50:31.330 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Cache.html for block at line 94. Keep only the first 100 references.
09:50:31.341 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Caching_File.php.html for block at line 58. Keep only the first 100 references.
09:50:31.368 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Init.php.html for block at line 58. Keep only the first 100 references.
09:50:31.376 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Filter.php.html for block at line 58. Keep only the first 100 references.
09:50:31.393 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Monitor.php.html for block at line 145. Keep only the first 100 references.
09:50:31.409 WARN Too many duplication references on file dwa/external/phpids/0.6/tests/coverage/Filter_Storage.php.html for block at line 58. Keep only the first 100 references.
09:50:31.462 INFO CPD Executor CPD calculation Finished (done) | time=303ms
09:50:31.902 INFO Analysis report generated in 397ms, dir size=10.2 MB
09:50:31.902 INFO Analysis report compressed in 18503ms, zip size=2.9 MB
09:50:30.501 INFO Analysis report uploaded in 93ms
09:50:30.503 INFO ANALYSIS SUCCESSFUL, you can find the results at: http://localhost:9000/dashboard?id=sample
09:50:30.517 INFO Note that you will be able to access the updated dashboard once the server has processed the submitted analysis report
09:50:30.525 INFO More about the report processing at http://localhost:9000/api/ce/task?id=59ea0a1-8269-4a84-98cf-cc8d642c736
09:50:31.066 INFO Analysis total time: 58.082 s
09:50:31.136 INFO SonarScanner Engine completed successfully
09:50:31.198 INFO EXECUTION SUCCESS
09:50:31.201 INFO Total time: 1:05:16ms
PS C:\Users\Administrator\Downloads>sonar-scanner-cli-7.2.0.5079-windows-x64\sonar-scanner-7.2.0.5079-windows-x64\bin>
PS C:\Users\Administrator\Downloads>sonar-scanner-cli-7.2.0.5079-windows-x64\sonar-scanner-7.2.0.5079-windows-x64\bin>
```

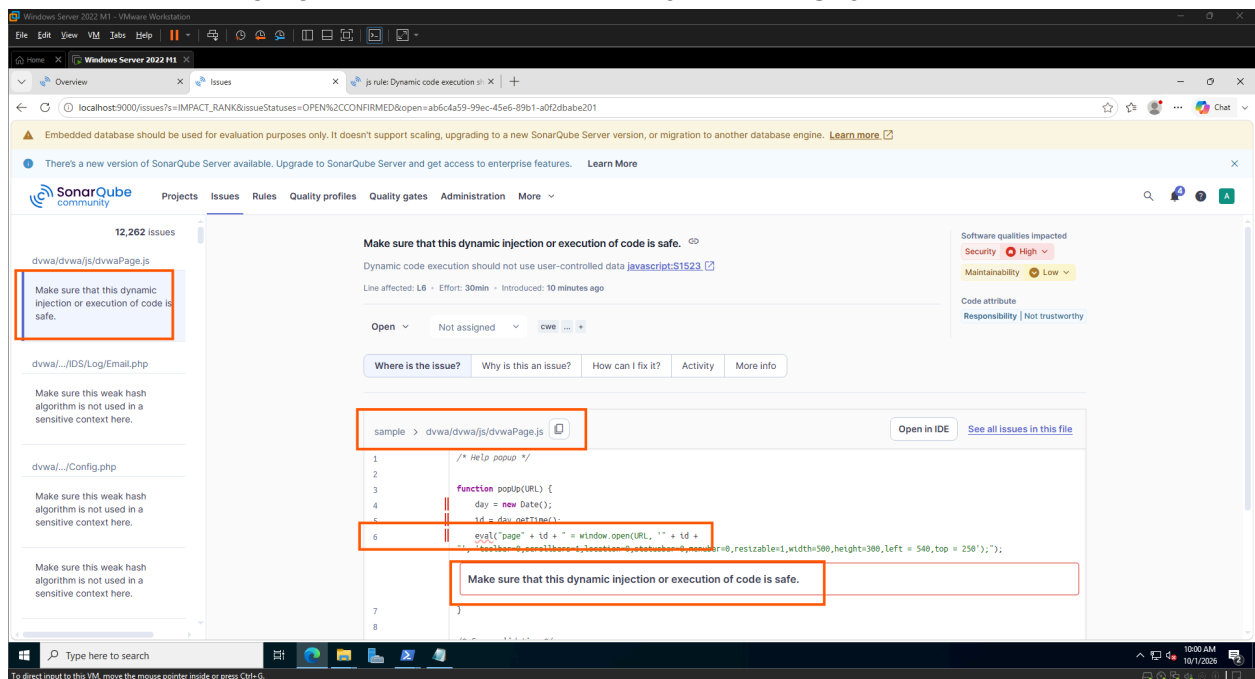
4.12 Open the browser, paste the generated URL, we can see the Overview page contains result highlights



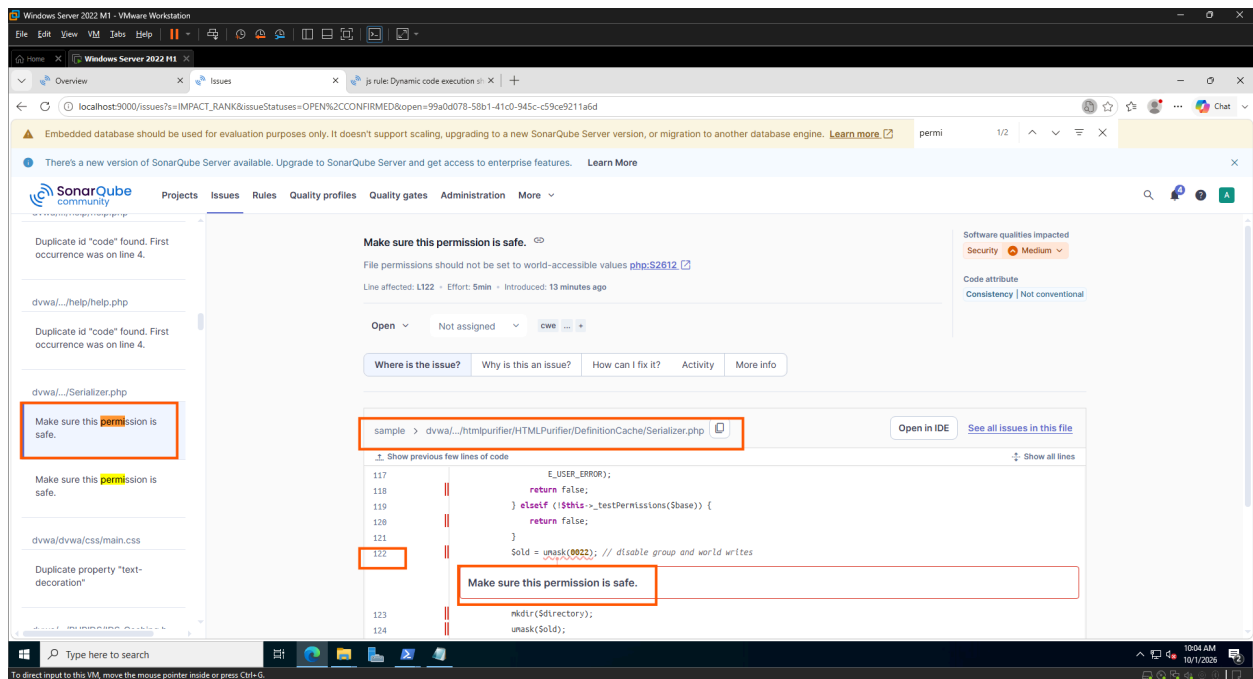
4.13 Navigate to issue tab & click on ***“Make sure that this dynamic injection or execution of code is safe”***



4.14 SonarQube highlights an issue in ***dvwa/dvwa/js/dvwaPage.js***.



4.15 Click on another issue called ***“Make sure this permission is safe.”*** SonarQube highlights an issue in ***dvwa/./htmlpurifier/HTMLPurifier/DefinitionCache/Serializer.php*** at line 122



Conclusion:

This exercise successfully demonstrates how to perform an end-to-end vulnerability scan using SonarQube on the DVWA source code. By completing each step, I have not only learned how to set up the required environment but also gained practical exposure to running SonarQube scans, reviewing detailed results, and understanding real-world security risks like code injection and insecure file permissions. This practical approach reinforces the importance of continuous code review and automated security testing as part of a secure software development lifecycle (SDLC).